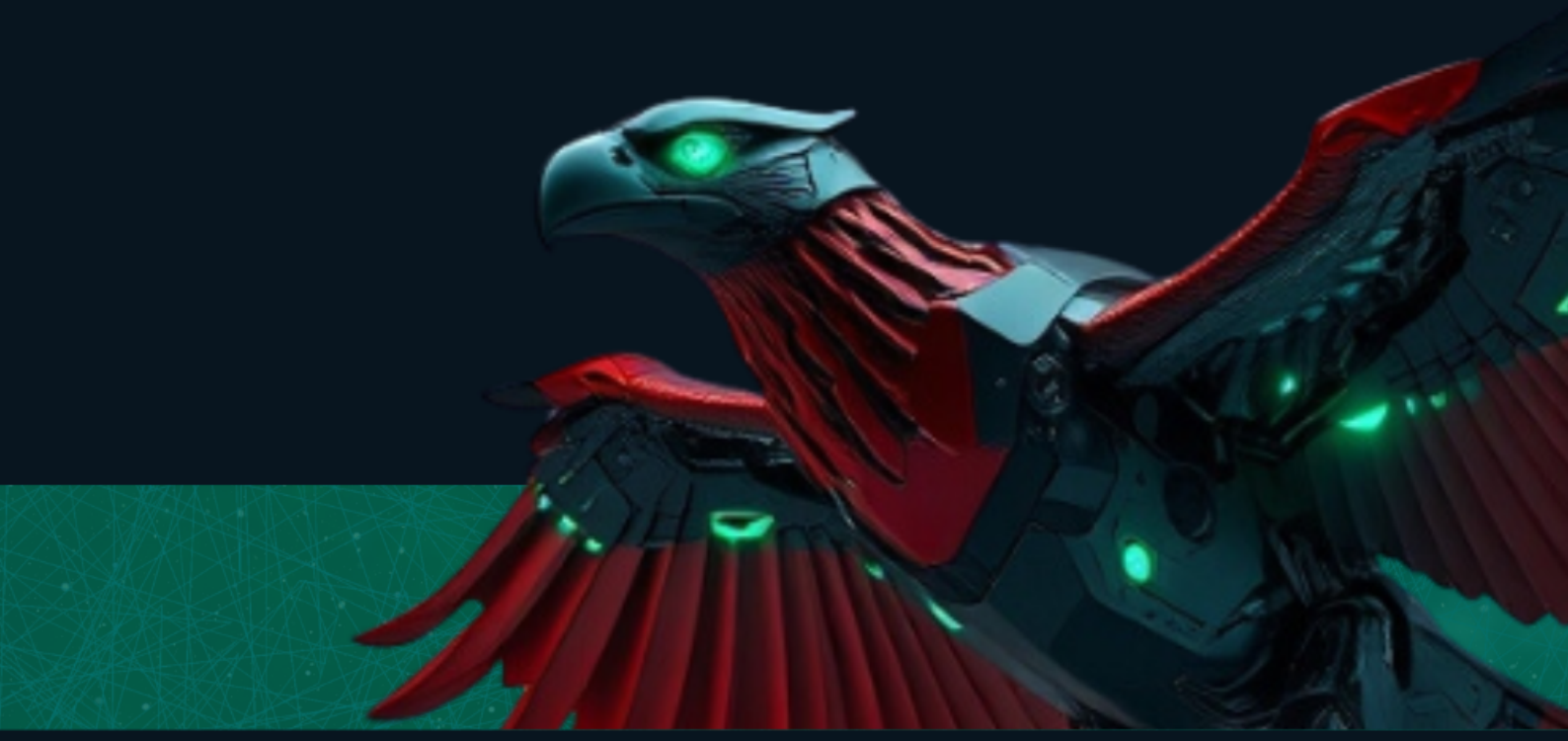
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	CVE-2026-20253
Sub Title	Unauthenticated user could create or truncate arbitrary files through a PostgreSQL sidecar service endpoint
Status	Closed
Type	Advisory
Severity	—
Source	Multiple Sources
Created At	Jun 29, 2026, 09:02 PM

CVE-2026-20253

Unauthenticated user could create or truncate arbitrary files through a PostgreSQL sidecar service endpoint

Type: ADVISORY • Source: Multiple Sources • Created At: Jun 29, 2026, 09:02 PM

Analysis Summary

The recently disclosed vulnerability, tracked as CVE-2026-20253, impacts Splunk Enterprise, a widely used data analytics and security monitoring platform owned by Splunk. The platform is heavily utilized by enterprises and large organizations globally to aggregate, analyze, and visualize machine-generated data for operational security and infrastructure visibility. The critical flaw was analyzed and detailed by security researchers Piotr Bazydlo and Yordan Ganchev of watchTowr Labs, who uncovered the issue through deep security analysis of the application's underlying architecture.

The vulnerability stems from a severe lack of authentication controls within Splunk's internal PostgreSQL sidecar service endpoints. An attacker can exploit this weakness remotely by interacting directly with the unauthenticated /v1/postgres/recovery/backup and /v1/postgres/recovery/restore endpoints. By using the backup endpoint, a remote individual can write a malicious database dump containing custom SQL queries onto the local file system. They can then invoke the restore endpoint to execute those queries within Splunk's local database instance, leveraging built-in database functions to write arbitrary content anywhere on the host file system.

This vulnerability poses a direct and catastrophic risk to an organization's infrastructure. Because the flaw provides an arbitrary file write primitive without requiring any credentials, an attacker can overwrite critical system files, such as Python scripts regularly executed by Splunk, to inject malicious payloads. This chain ultimately grants the attacker unauthenticated Remote Code Execution (RCE) with the privileges of the Splunk software. Left unmitigated, this allows full compromise of the host server, potential lateral movement into the broader corporate network, and unauthorized access to sensitive operational logs.

Affected Product

- Splunk Enterprise 10.2 - versions prior to 10.2.4
- Splunk Enterprise 10.0 - versions prior to 10.0.7

Impact

- Exploit Public-Facing Application — T1190
- Command and Scripting Interpreter — T1059
- Ingress Tool Transfer — T1105
- Impair Defenses: Disable or Modify Tools — T1562.001
- Data from Local System — T1005
- Indicator Removal on Host — T1070

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-20253	In Splunk Enterprise 10.2 versions below 10.2.4 and 10 versions below 10.0.7, an unauthenticated user could create or truncate arbitrary files through a PostgreSQL sidecar service endpoint. The vulnerability exists because the PostgreSQL sidecar service endpoint lacks authentication controls, allowing any network-reachable user to invoke file operations without credentials. Splunk Enterprise versions 9.4 and earlier are not affected. If you cannot immediately upgrade to a fixed version, you can mitigate this vulnerability by disabling the PostgreSQL sidecar service.	5/7/2026	8.8

Remediation

- Restrict network access to the sidecar service (host firewall or upstream firewall) so only the Splunk host itself or tightly defined admin subnets can reach /v1/postgres/recovery/* paths.watchtowr+1
- If reverse proxies or API gateways front the service, enforce strong authentication (mTLS or service account tokens) and IP allow listing for those endpoints.
- Validate that in patched versions, the sidecar endpoints enforce auth and cannot be used by unauthenticated users for backup/restore operations.watchtowr+1
- Confirm the .pgpass file referenced in exploitation (/opt/splunk/var/packages/data/postgres/.pgpass) is protected by OS level permissions and not world readable, and ensure only the Splunk/Postgres service account can access(it.watchtowr)